REVUE DE PRESSE HEBDOMADAIRE

Software Compliance

L'essentiel de la conformité des logiciels embarqués dans les produits de défense

N° 4 – Mardi 27 octobre 2026

Revue de presse hebdomadaire, tous les mardis

Deux failles critiques de PHP, déjà exploitées, mettent à l'épreuve la déclaration des vulnérabilités du CRA ; LiteLLM a été piégé sur PyPI et des clés d'autorités de certification eMudhra sont compromises ; le Royaume-Uni annonce pour décembre la mise à jour de ses listes de contrôle ; Oracle publie la première mise à jour de JDK 21 sous licence OTN.

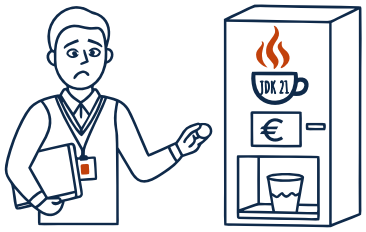
DANS CE NUMÉRO

SBOM et normes 1
Outils 2
Chaîne d'approvisionnement 2
Commerce international 3
France et UE 4
Licences 4
Glossaire 4
Agenda 4

À LA UNE

Failles de PHP, la déclaration du CRA à l'épreuve

À propos de deux failles critiques de PHP exploitées, les autorités européennes rappellent que les fabricants doivent déclarer les vulnérabilités activement exploitées depuis le 11 septembre 2026.



Oracle JDK 21 : les mises à jour publiées à partir du correctif trimestriel (CPU) d'octobre 2026, daté du 20 octobre, sont prévues sous licence Java SE OTN ; l'usage en production devient payant au-delà des autorisations gratuites de cette licence ; Oracle JDK 25 reste sous licence NFTC jusqu'en septembre 2028.

Jusqu'ici, JDK 21 était gratuit en production et redistribuable sous la licence NFTC (*No-Fee Terms and Conditions*). La licence OTN qui couvre ses versions 21.0.13 et suivantes en diffère substantiellement, selon Oracle : certains usages permis par les licences antérieures peuvent ne plus l'être.

Un équipement qui embarque en production ces nouveaux correctifs de JDK 21 entre dans le champ de la redevance : l'industriel doit recenser ses produits concernés, avec des SBOM qui distinguent Oracle JDK des distributions OpenJDK. Un produit maintenu plusieurs années pourrait devoir migrer vers JDK 25 ou vers une distribution OpenJDK, au prix d'une nouvelle qualification du logiciel.

EN BREF

Java 8, 11 et 17 : les versions d'Oracle JDK sont déjà proposées sous licence OTN, gratuite pour les seuls usages personnels, de développement et assimilés.

OpenJDK : Oracle publie aussi sur jdk.java.net des versions de production sous licence GPLv2 avec exception *Classpath*, aujourd'hui JDK 27.

SBOM, NORMES ET RÉFÉRENTIELS

L'ENISA publie un guide technique du SBOM ; CycloneDX 2.0 et les normes du CRA restent attendus.

AI Act : l'EN 18286, première norme harmonisée citée au Journal officiel

AI Act, première norme harmonisée : la Commission a annoncé le 19 octobre 2026 la publication au JO de la référence de l'EN 18286:2026 (système de management de la qualité), par la décision d'exécution (UE) 2026/2274 ; elle donne une présomption de conformité à l'article 17.

Élaborée par le CEN et le CENELEC, la norme suit tout le cycle de vie du système d'IA ; elle se superpose à ISO/IEC 42001 ou à ISO 9001 sans les remplacer. Elle répond au volet de la demande de normalisation du 23 juin 2025 consacré au management de la qualité, processus de surveillance après commercialisation compris. Datée du 12 octobre, la décision est entrée en vigueur le jour de sa parution au Journal officiel, le 14 octobre.

Un fournisseur de système d'IA à haut risque peut désormais s'appuyer sur elle pour son système de management de la qualité. Le système exigé couvre notamment la notification des incidents graves et la gestion des ressources, sécurité d'approvisionnement comprise. Un fournisseur déjà tenu à un système qualité par une autre législation sectorielle de l'Union peut y intégrer ces exigences. Pour un produit à double usage qui intègre de l'IA, hors de l'exclusion défense, elle pourrait devenir une référence attendue par les clients civils.

La Commission annonce d'autres normes harmonisées avant l'application des exigences sur les systèmes à haut risque. Selon le CEN-CENELEC, la norme traduit les exigences du règlement sur le système qualité en exigences pratiques, vérifiables par audit ; sa publication a coïncidé avec la Journée mondiale de la normalisation.

EN BREF

CycloneDX 2.0 : version attendue à l'automne 2026, ratification par Ecma en décembre ; le format s'étendrait aux modèles de menaces et à la provenance des composants physiques.

Normes du CRA : 17 projets de normes verticales de l'ETSI en enquête publique jusqu'à mi-novembre 2026 ; aucune norme du CRA n'est encore citée au Journal officiel.

OUTILS ET SERVICES DE CONFORMITÉ

cdxgen corrige une faille critique de son mode serveur ; Dependency-Track et ORT publient de nouvelles versions.

Trivy 0.76 : nouvelles sources de correctifs et CBOM enrichi

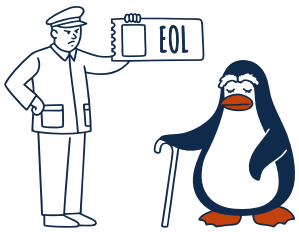
Trivy 0.76 : le scanneur d'Aqua Security détecte désormais les vulnérabilités des paquets Maven et npm corrigés par Echo, analyse les images RapidFort fondées sur Debian, Oracle Linux, Rocky Linux, AlmaLinux et Amazon Linux, et indique le niveau de sécurité nominal des algorithmes de sa nomenclature cryptographique (CBOM), fonction encore expérimentale.

Le niveau de sécurité se lit sur deux échelles : la résistance en bits aux attaques classiques et la catégorie post-quantique du NIST, de 1 à 5, ou 0 pour un algorithme qui n'en atteint aucune.

Publiée le 14 octobre, la version demande normalement une connexion Internet ; sa documentation décrit la configuration d'un réseau restreint ou entièrement isolé : les bases peuvent y être hébergées dans un registre interne, et Maven Central n'y est pas utilisable.

Les équipes qui comparent des CBOM successifs doivent prévoir le changement d'identifiant des composants DSA, la fonction pouvant évoluer sans garantie de rétrocompatibilité. Le niveau de sécurité nominal pourrait aider à repérer la cryptographie faible d'un produit et à documenter les fonctions de chiffrement examinées pour le contrôle des exportations.

Syft 1.55 et Grype 0.121 : paquets IPK et fin de support des distributions



Syft 1.55 et Grype 0.121 : publiés le 19 octobre 2026 par Anchore, le générateur de SBOM inventorie désormais les paquets IPK, et le scanneur de vulnérabilités tient compte de la date de fin de support publiée par les distributions pour ses alertes de fin de vie.

Format du gestionnaire opkg, l'IPK reprend la structure des paquets deb : Syft le lit donc avec son catalogueur d'archives deb. Grype retrouve aussi les avis GitHub des paquets Swift Package Manager.

Les dates de fin de vie venaient jusqu'ici du projet endoflife.date ; Grype lit désormais aussi celle que déclare le fichier de version du système analysé. Passé la fin de vie, il ne signale que les vulnérabilités suivies auparavant par le mainteneur : un rapport vierge sur un tel système ne prouve pas l'absence de faille, et l'alerte doit être traitée comme une lacune de couverture.

Sur un réseau isolé, Grype exige l'import manuel d'une base récente au moins tous les cinq jours avec le réglage par défaut, faute de quoi ses analyses échouent ; Syft fonctionne sans connexion une fois la vérification de mise à jour désactivée. La prise en charge des IPK pourrait étendre l'inventaire aux micrologiciels Linux embarqués qui utilisent ce format.

Privateer : évaluation automatisée de la sécurité et de la conformité

Privateer : l'OpenSSF a annoncé le 13 octobre 2026 l'entrée dans son bac à sable (*Sandbox*) de ce cadre d'évaluation automatisée de la sécurité et de la conformité, à base d'extensions ; les contrôles déterministes passent d'abord, l'IA est facultative, et ses résultats ne déterminent pas la conformité juridique.

Chaque contrôle ressort réussi, échoué ou « à revoir », ce dernier cas laissant la décision à un humain : l'outil évalue sans bloquer les constructions non conformes, à la différence d'un moteur comme AMPEL.

Des extensions examinent dépôts, configurations, infrastructures et systèmes déployés au regard de catalogues de contrôles tenus à part, comme le référentiel OSPS Baseline.

L'option d'IA de l'extension GitHub transmet les documents déclarés au fournisseur configuré : pour un code soumis au contrôle des exportations, l'industriel doit vérifier qu'un tel transfert est autorisé. Pour les dépôts GitHub, seul le premier niveau de maturité du référentiel est recommandé : les résultats des niveaux 2 et 3, encore en développement, sont à relire. Sans l'option d'IA, l'outil pourrait servir à documenter la préparation au CRA de composants open source.

EN BREF

Plateforme unique du CRA : lancée par l'ENISA le 11 septembre 2026, elle reçoit les déclarations des fabricants.

Chainguard : images durcies livrées avec SBOM signé, mises à jour quotidiennes et délai de 7 jours pour les CVE critiques (promesse de l'éditeur).

SÉCURITÉ DE LA CHAÎNE D'APPROVISIONNEMENT

LiteLLM a été piégé sur PyPI et Docker, des clés d'autorités de certification eMudhra sont compromises, OVHcloud détaille la cause du piégeage de son CLI ; la CISA publie sa stratégie et l'OpenSSF un guide sur la correction des vulnérabilités avec l'IA.

OVHcloud : versions du CLI officiel piégées sur GitHub

OVHcloud CLI : le 19 octobre 2026, pendant environ une heure et demie, les versions v0.11 à v0.15 de l'outil, distribuées depuis son dépôt GitHub officiel, ont embarqué un binaire qui cherchait les secrets sur l'ordinateur ; une vérification de l'empreinte SHA-256 a révélé l'attaque ; la v0.16 est publiée.

Les versions touchées, parues d'avril à septembre, ont été modifiées après coup ; selon Octave Klaba, l'attaquant a utilisé le compte GitHub d'un développeur. Le code source du CLI lui-même n'était pas nécessairement compromis.

Les secrets recherchés peuvent être des clés d'API, des jetons d'accès, des identifiants cloud ou des clés SSH.

La version corrective porte un *tag* GitHub signé, et ses fichiers de publication sont désormais déclarés immuables. Les premières vérifications d'OVHcloud n'ont trouvé aucun autre dépôt touché ; un post-mortem détaillé est annoncé.

Tout poste ou serveur qui a exécuté l'une des versions piégées doit être traité comme exposé : ses clés, jetons et mots de passe techniques sont à révoquer et à renouveler. Un dépôt officiel pouvant distribuer un logiciel malveillant, une chaîne de construction doit aussi figer l'empreinte des binaires tiers qu'elle télécharge. Sans cette précaution, un composant piégé pourrait entrer dans un produit livré, et des secrets volés sur un poste de développement ouvrir l'accès aux dépôts de l'industriel.

GhostAction : vol d'identifiants par les GitHub Actions, puis par VS Code



GhostAction : selon GitGuardian, cité par The Hacker News, cette campagne de vol d'identifiants

vise plus de 30 000 dépôts de 3 000 utilisateurs et organisations, après la compromission d'environ 1 900 comptes GitHub ; une nouvelle étape fait exécuter par VS Code un voleur d'identifiants caché dans une fausse police.

La campagne a tenté d'extraire 3 174 secrets des chaînes d'intégration de dépôts publics, au moyen d'un *workflow* déguisé en audit de sécurité ; GitHub le bloque depuis le 9 octobre. Les comptes ont été pris avec des jetons d'accès volés ou des identifiants tirés de journaux d'*infostealers*.

La seconde étape échappe à ce blocage : elle se passe de GitHub Actions et persiste après la suppression du *workflow*. Repérée dans 94 dépôts de 66 propriétaires, elle installe chez la victime une tâche planifiée qui exécute toutes les cinq minutes les commandes de l'attaquant.

Si l'exécution automatique des tâches est autorisée dans VS Code, ouvrir un dépôt piégé suffit à lancer le voleur sur le poste du développeur : ce réglage est à vérifier, et le propriétaire d'un dépôt touché doit prévenir ceux qui l'ont cloné. Sur ses dépôts, l'industriel peut exiger une approbation avant l'exécution des *workflows* et une revue obligatoire de leurs modifications. Des jetons de publication volés pourraient servir à diffuser des versions piégées de composants open source.

GitHub : alertes de paquets malveillants étendues à huit écosystèmes

Paquets malveillants : selon une étude de cas de l'OpenSSF du 16 octobre 2026, GitHub a intégré à sa base d'avis les données du dépôt *Malicious Packages* de l'OpenSSF, plus de 238 000 signalements, et couvre désormais huit écosystèmes, dont npm, PyPI, Maven et crates.io.

Ce dépôt public, lancé en octobre 2023, publie ses signalements au format OSV. La chaîne d'avis de GitHub était centrée sur npm, et étendre sa détection aux autres écosystèmes aurait pris des années.

Les avis de logiciels malveillants sont publiés automatiquement, sans relecture au cas par cas, par choix délibéré.

Ces alertes restent facultatives : un dépôt dont les alertes Dependabot sont activées doit aussi les demander pour être prévenu qu'une dépendance figure parmi ces paquets. Dès l'activation, Dependabot confronte les dépendances existantes aux avis déjà publiés ; une organisation peut déployer ces alertes sur ses dépôts par ses configurations de sécurité. Un paquet interne qui porte le nom d'un paquet public malveillant peut déclencher une fausse alerte, que des règles de tri automatique de Dependabot permettent d'écarter. Ouvertes, ces données pourraient être confrontées aux SBOM des produits pour repérer un composant malveillant dans un logiciel déjà livré.

EN BREF

Trivy, 19 mars 2026 : la version 0.69.4 et des actions GitHub de l'outil ont distribué un code volant des secrets.

Attaque du 11 mai 2026 : 404 versions malveillantes de paquets npm et PyPI, dont TanStack et Mistral AI.

COMMERCE INTERNATIONAL — Exportations et sanctions

Le Royaume-Uni annonce pour décembre la mise à jour de ses listes de contrôle ; les dossiers ITAR, CMMC et sanctions restent ouverts.

UE : sanctions contre des intermédiaires qui contournent les mesures visant la Russie



Sanctions, contournement : par le règlement d'exécution (UE) 2026/2333 du 15 octobre 2026, le Conseil inscrit trois personnes et neuf entités, dont des sociétés de commerce impliquées dans l'importation en Russie de biens soumis aux mesures de l'Union.

Le texte, qui met en œuvre le règlement (UE) n° 269/2014, entre en vigueur dès sa publication au Journal officiel. Parmi les inscrits figurent Movers Group LLC, pour l'importation parallèle, et DT Inier LLC, courtier en douane qui organise des routes indirectes par des pays tiers et propose des solutions d'approvisionnement « clés en main » pour contourner les restrictions. Begler Tekstil Insaat Elektronik ve Dis Ticaret, société de commerce et de logistique, est visée pour la fourniture de produits soumis aux mesures.

Les entités sont établies en Russie, en Turquie, aux Émirats arabes unis, en Inde et aux Seychelles ; plusieurs gèrent des navires qui transportent du pétrole russe, dont certains de la flotte fantôme.

Les inscriptions visent des intermédiaires et pas seulement des entreprises russes : le filtrage des distributeurs, transitaires et clients doit intégrer la liste mise à jour. Le règlement de base gèle les avoirs des inscrits et interdit de mettre à leur disposition, directement ou indirectement, des fonds ou des ressources économiques, actifs incorporels compris. Livrer un logiciel, une licence ou une mise à jour à un intermédiaire inscrit pourrait constituer une violation des mesures de l'Union.

Royaume-Uni : licences générales d'exportation élargies

Royaume-Uni, licences générales : depuis le 14 octobre 2026, l'ECJU étend la licence générale ouverte (OGEL) *dual-use* à douze nouvelles destinations et élargit les deux OGEL des biens, logiciels et technologies militaires, la plus large s'ouvrant notamment à la Pologne, à la Grèce et à la Corée du Sud.

L'OGEL *dual-use* couvre des équipements aéronautiques et maritimes, les technologies de l'information, les semi-conducteurs avancés et le quantique. Parmi les douze nouvelles destinations figurent Bahreïn, le Maroc, Oman, les Philippines et le Qatar.

L'OGEL militaire réservée aux utilisateurs finaux gouvernementaux ou de l'OTAN s'ouvre au Chili, au Monténégro, à la Jordanie, au Koweït et à la Macédoine du Nord, entre autres.

Une entité britannique peut ainsi exporter vers ces pays sans demande individuelle, si elle respecte les conditions des OGEL ; l'ECJU estime éviter plus de 800 demandes par an et pouvoir examiner plus vite les licences les plus sensibles. Pour l'OGEL *dual-use*, l'exportateur doit s'enregistrer sur SPIRE, le système de licences en ligne, avant le premier usage, en indiquant où l'ECJU peut inspecter ses registres, et, pour les exportations concernées, porter la référence de la licence dans la déclaration en douane. Sans avis de classement officiel, l'exportateur devrait toutefois établir lui-même que ses biens entrent dans le champ de ces licences.

EN BREF

Sanctions, 22e paquet : adopté le 12 octobre 2026, il inscrit 1 569 personnes et entités, dont des fournisseurs de composants du complexe militaro-industriel russe.

Sanctions : le 21e paquet de l'UE contre la Russie (23 juillet 2026) laisse jusqu'au 25 octobre pour exécuter certains contrats antérieurs.

Royaume-Uni, classement : le service CLC de l'ECJU reste suspendu depuis le 12 octobre 2026, sans date de reprise.

***Dual-use* UE** : le règlement délégué du 14 septembre 2026 met à jour l'annexe I et étend les contrôles sur les logiciels de nouveaux équipements semi-conducteurs.

CMMC : la suspension de la phase 2, décidée le 13 juillet 2026, reste sans date de reprise ; NIST SP 800-171 et DFARS 252.204-7012 restent applicables.

ITAR-free : Honeywell a chargé 1 000 ingénieurs en Pologne et en Tchéquie de concevoir des technologies non-ITAR face à la demande européenne.

FRANCE ET UE — NIS2, IA, défense

Le Conseil arrête sa position sur la déclaration des incidents du Digital Omnibus ; la loi Résilience attend toujours une date d'examen.

Loi Résilience : pas de réinscription le 13 octobre 2026



Mise à jour, loi Résilience : la conférence des présidents de l'Assemblée nationale du 13 octobre 2026 n'a pas réinscrit le projet de loi transposant NIS2, DORA et REC ; la suivante se réunit le 20 octobre.

Le relevé de conclusions porte sur le calendrier de contrôle de la session et ne mentionne pas le texte ; le dossier législatif n'indique aucune date de séance publique. Adopté en première lecture par le Sénat le 12 mars 2025, le projet attend l'examen en séance du texte de sa commission spéciale, arrêté le 10 septembre 2025.

Les obligations françaises issues de NIS2 restent sans date d'adoption : les entités concernées ne connaissent ni le texte définitif ni son calendrier. Selon l'exposé des motifs, le nombre d'entités régulées passerait d'environ 500 à près de 15 000. Les amendes pourraient atteindre 10 millions d'euros ou 2 % du chiffre d'affaires annuel mondial pour une entité essentielle, 7 millions ou 1,4 % pour une entité importante.

Un fournisseur doit se préparer à des clauses contractuelles : le Référentiel Cyber France, document de travail de l'ANSSI, demande aux entités régulées de recenser leurs prestataires informatiques et de s'assurer, notamment par contrat, de la conformité de leurs prestations. Ce document, comme le projet de loi, pourrait évoluer.

EN BREF

Omnibus défense : le Parlement européen a adopté le 16 septembre 2026 la directive sur les transferts intra-UE de produits de défense, avec de nouvelles licences générales de transfert.

SAFE et EDIP : deux appels EDIP (180 M€ et 90 M€) se sont clôturés le 13 octobre ; SAFE plafonne à 35 % le coût des composants de pays tiers.

LICENCES OPEN SOURCE ET LOGICIELS EMBARQUÉS

Oracle publie la première mise à jour de JDK 21 sous licence OTN, qui ne permet pas la redistribution ; les contentieux Vizio et Bambu Lab restent ouverts.

Russie : une suite fondée sur LibreOffice refusée au registre des logiciels nationaux

Russie, droits sur un logiciel dérivé : le 7 octobre 2026, le tribunal d'arbitrage de Moscou a validé le refus du ministère du Numérique d'inscrire « Free Office », de BaseALT, au registre des logiciels russes ; l'éditeur ne détenait pas les droits sur LibreOffice, composant central.

Pour le tribunal, la localisation russe, les dictionnaires et l'intégration de la signature électronique ne suffisaient pas à fonder une propriété indépendante. Selon l'avocat Denis Dorotenko, cinq des sept programmes de la suite sont des développements tiers sous licence ouverte : si le titulaire de l'un d'eux modifiait sa licence ou y mettait fin, l'usage de l'ensemble deviendrait illicite.

L'inscription a des effets concrets : distinct d'un dépôt de droits d'auteur, le registre ouvre des avantages fiscaux sur les licences et les cessions de droits, et facilite l'accès aux marchés publics.

La décision ne vaut qu'en Russie et peut faire l'objet d'un appel ; elle invite à documenter la part de code propre d'un produit dérivé de composants open source. Une déclaration d'origine ou de propriété d'un logiciel, demandée par un client ou par un programme de production nationale, pourrait être contestée si le produit repose surtout sur de tels composants ; selon Heather Meeker, la décision pourrait peser sur de futurs litiges portant sur le respect des licences open source en Russie.

EN BREF

GPL, SFC contre Vizio : le procès est indiqué par la SFC pour fin 2026 ; aucun verdict n'a été relevé dans les sources consultées.

AGENDA — Dates à surveiller

10 NOV. — EXPORT ÉTATS-UNIS
Réimposition automatique de la règle des affiliés du BIS, sauf prolongation

NOV. 2026 — EXPORT UE
Règlement délégué adopté le 14 septembre 2026 ; publication au JO après deux mois d'examen du Parlement européen et du Conseil, sauf objection

30 NOV. — EXPORT ÉTATS-UNIS
Projet publié le 1er octobre 2026 : retrait de certains articles de la liste, définitions révisées, nouvelle exemption de licence

DÉC. 2026 — EXPORT ROYAUME-UNI
Mise à jour des listes militaire et dual-use (biens, logiciels, technologies) annoncée par l'avis aux exportateurs 2026/24

9 DÉC. — RESPONSABILITÉ PRODUIT
Transposition de la directive (UE) 2024/2853, qui inclut le logiciel ; elle s'applique aux produits mis sur le marché à partir de cette date

DÉC. 2027 — AI ACT
Règles sur les systèmes d'IA à haut risque de l'annexe III, reportées à cette date par le règlement (UE) 2026/1744

DÉC. 2027 — CRA
Application complète du CRA ; selon l'ENISA, les gestionnaires de logiciels open source sont soumis à la déclaration à la même date

GLOSSAIRE — Sigles et termes cités

cdxgen Outil open source du projet CycloneDX qui génère des SBOM pour de nombreux langages et peut fonctionner comme service HTTP.

CERT-EU Service de cybersécurité des institutions

CERT-FR Centre gouvernemental de veille

CRA Cyber Resilience Act

eMudhra Autorité de certification indienne qui délivre des certificats TLS et de signature, dont des autorités intermédiaires reconnues par les navigateurs.

ENISA Agence de l'Union européenne pour la cybersécurité

HBOM Hardware Bill of Materials

LiteLLM Bibliothèque Python open source et passerelle qui donnent accès à de nombreux modèles d'IA par une interface commune.

SBOM Software Bill of Materials

SCANOSS Outil et service de détection de composants open source et de leurs licences par comparaison d'empreintes de code

Software Compliance
Revue de presse hebdomadaire, N° 4 du 27 octobre 2026.
Rédigée par une intelligence artificielle (Claude Opus 5.5), peut comporter des erreurs : pensez à croiser vos sources.
Édition en ligne avec sources : revue.dejeun.es/2026-10-27
© 2026 Rodolphe Dejeunes, publié sous licence CC BY 4.0.